Практическое занятие №3

Цель работы

- создавать пользователей в СУБД;
- настраивать их аутентификацию;
- назначать разные права доступа;
- проверять возможность выполнения разрешённых и запрещённых операций;
- применять принцип минимальных привилегий;
- блокировать и удалять учётные записи.

Рекомендуемая СУБД

PostgreSQL, MySQL или MS SQL Server.

1. Краткая теория

Перед выполнением работы студент должен вспомнить:

Идентификация

Определение того, **какую учётную запись использует пользователь**.

Аутентификация

Проверка того, что пользователь действительно является владельцем учётной записи.

Например:

Логин: student01

Пароль: ********

Авторизация

Определение того, **какие действия разрешены пользователю**.

Например:

student01 → SELECT

teacher01 → SELECT + UPDATE

admin01 → административные операции

Главный принцип:

Пользователь должен получать только те права, которые необходимы ему для работы.

Представим информационную систему университета.

В базе данных есть таблица:

```
CREATE TABLE students (
    id SERIAL PRIMARY KEY,
    full_name VARCHAR(100),
    group_name VARCHAR(50),
    email VARCHAR(100),
    scholarship DECIMAL(10,2)
```

Добавим несколько записей:

```
INSERT INTO students (full_name, group_name, email, scholarship)
VALUES
('Иванов Иван', 'IT-23', 'ivanov@mail.ru', 50000),
('Петров Петр', 'IT-23', 'petrov@mail.ru', 45000),
('Сидорова Анна', 'IT-24', 'sidorova@mail.ru', 50000);
```

В системе должны работать три типа пользователей:

1. student_user

Обычный студент.

Ему необходимо разрешить:

- просматривать информацию о студентах.

2. teacher_user

Преподаватель.

Ему необходимо разрешить:

- просматривать студентов;
- изменять данные студентов.

3. db_admin

Администратор базы данных.

Он отвечает за:

- управление пользователями;

- настройку прав;
- обслуживание БД.

3. Задание №1. Создание пользователей

Создайте три учётные записи.

В PostgreSQL:

```
CREATE USER student_user
WITH PASSWORD 'Student_Strong_123!';

CREATE USER teacher_user
WITH PASSWORD 'Teacher_Strong_123!';

CREATE USER db_admin
WITH PASSWORD 'Admin_Strong_123!';
```

Проверьте созданные учётные записи:

```
SELECT usename
FROM pg_user;
```

4. Задание №2. Настройка прав

Теперь необходимо предоставить пользователям разные права.

Студент

Студенту достаточно права на чтение:

```
GRANT CONNECT ON DATABASE university TO student_user;

GRANT USAGE ON SCHEMA public TO student_user;

GRANT SELECT ON students TO student_user;
```

Проверяем:

```
SELECT *
FROM students;
```

Пользователь должен иметь возможность выполнить запрос SELECT.

Преподаватель

Преподавателю разрешаем чтение и изменение данных:

GRANT CONNECT ON DATABASE university TO teacher_user;

GRANT USAGE ON SCHEMA public TO teacher_user;

GRANT SELECT, INSERT, UPDATE ON students TO teacher_user;

Преподаватель сможет выполнять:

SELECT * FROM students;

и, например:

UPDATE students

SET scholarship = 55000

WHERE id = 1;

Администратор

Администратору предоставляются расширенные полномочия.

В учебной лаборатории можно использовать:

ALTER USER db_admin WITH SUPERUSER;

5. Задание №3. Проверка прав пользователей

Теперь необходимо проверить, действительно ли пользователи имеют **разные возможности**.

Проверка студента

Подключитесь к БД под:

student_user

Выполните:

SELECT *

FROM students;

Запрос должен выполниться.

Теперь попробуйте:

UPDATE students

SET scholarship = 100000

WHERE id = 1;

Операция должна быть запрещена.

Запишите результат:

Операция	**Результат**
SELECT	Разрешено
UPDATE	Запрещено
DELETE	Запрещено
CREATE USER	Запрещено

6. Проверка преподавателя

Подключитесь под:

teacher_user

Выполните:

SELECT *

FROM students;

Затем:

UPDATE students

SET scholarship = 55000

WHERE id = 1;

Проверяем:

SELECT *

FROM students

WHERE id = 1;

Теперь попробуйте:

DELETE FROM students

WHERE id = 1;

Если право DELETE не предоставлялось, СУБД должна отказать в выполнении операции.

Таким образом:

teacher_user

↓

SELECT □

INSERT □

UPDATE □

DELETE ✗

CREATE USER ✗

7. Задание №4. Настройка принципа минимальных привилегий

Представьте, что преподавателю необходимо только:

- просматривать студентов;
- изменять оценки.

Но в нашей учебной таблице students преподавателю были предоставлены:

SELECT

INSERT

UPDATE

Задание:

Определите, какие права можно удалить.

Например:

REVOKE INSERT ON students FROM teacher_user;

Теперь преподаватель может:

SELECT □

UPDATE □

INSERT ✗

DELETE ✗

Это пример реализации принципа:

Least Privilege — минимально необходимые привилегии.

8. Задание №5. Блокировка пользователя

Представим, что студент временно не должен иметь доступа к системе.

В PostgreSQL можно установить:

ALTER USER student_user NOLOGIN;

Теперь учётная запись существует, но войти с её помощью нельзя.

Для восстановления доступа:

ALTER USER student_user LOGIN;

9. Итоговая таблица прав

После выполнения работы студент должен получить примерно такую модель:

Пользователь	**Аутентификация**	**SELECT**	**INSERT**	**UPDATE**	**DELETE**	**Управление пользователями**
student_user	пароль	□	✗	✗	✗	✗
teacher_user	пароль	□	✗	□	✗	✗
db_admin	пароль	□	□	□	□	□

Главная идея:

Student
↓
минимальные права

Teacher
↓
расширенные рабочие права

Administrator
↓
административные права

10. Итоговое задание

создать ещё одного пользователя:

analyst_user

Для него необходимо настроить следующие права:

- подключение к БД;
- просмотр таблицы students;
- запрет изменения данных;
- запрет удаления данных;
- запрет создания пользователей.

Затем проверить работу:

SELECT * FROM students;

и попытаться выполнить:

UPDATE students

SET scholarship = 60000

WHERE id = 1;

Результат необходимо зафиксировать.

11. Что должно быть в отчёте

1. Цель работы

Например:

Цель работы — освоить создание пользователей в СУБД, настройку аутентификации и разграничение прав доступа.

2. Созданные пользователи

Пользователь	**Назначение**
student_user	Студент
teacher_user	Преподаватель
db_admin	Администратор
analyst_user	Аналитик

3. SQL-команды

Привести основные использованные команды:

CREATE USER

GRANT

REVOKE

ALTER USER

4. Матрица прав

Представить таблицу:

Пользователь	SELECT	INSERT	UPDATE	DELETE
Student	□	✗	✗	✗
Teacher	□	✗	□	✗
Admin	□	□	□	□
Analyst	□	✗	✗	✗

5. Результаты проверки

Написать:

- какие операции были разрешены;
- какие операции были запрещены;
- какие ошибки выдала СУБД.